

Audit de sécurité

Application La Tournée, cinq dépôts. Application web progressive, Android, iOS, contenu et site vitrine.

Ce qu'il faut retenir

L'audit ne trouve **aucune vulnérabilité critique** et aucun secret dans le code publié. Le scan de l'historique complet des cinq dépôts, soit 305 commits, ne remonte **aucune correspondance** sur les motifs de clés connus. Le noyau applicatif est sain : aucun point d'injection de code dans les pages, aucune donnée personnelle qui quitte l'appareil, un consentement conforme aux recommandations de la CNIL.

Les trois constats de gravité élevée ne portent pas sur le produit lui-même mais sur la **chaîne d'outillage autour** : des identifiants d'administration exposés au processus de déploiement, une chaîne de publication mobile trop permissive, et l'absence d'en-têtes de sécurité sur le site. Les trois se corrigent en quelques fichiers de configuration.

Gravité	Nombre	Nature
CRITIQUE	0	Rien à signaler
ÉLEVÉ	3	Exposition d'identifiants, chaîne de publication, en-têtes
MOYEN	6	Falsification du premium, couverture du scan, hygiène des dépôts
FAIBLE	7	Durcissements complémentaires
POINTS FORTS	8	Acquis vérifiés à préserver

Constats de gravité élevée

E1. Trois identifiants d'administration exposés au processus de déploiement

Le fichier d'environnement local du dépôt web contient une clé serveur RevenueCat, un jeton Sentry et une clé personnelle PostHog. La clé RevenueCat permet d'octroyer des droits payants, de lire la base clients et de déclencher des remboursements.

Le fichier est correctement ignoré par Git, et le paquet publié est propre : la recherche de motifs de clés secrètes sur le répertoire de distribution ne remonte rien. Le problème est ailleurs. Il n'existe **aucun fichier d'exclusion Vercel** alors que l'usage de l'outil en ligne de commande est attesté par la configuration présente dans le dépôt. Un déploiement lancé depuis ce dossier téléverse le contexte de compilation, donc potentiellement ce fichier.

CORRECTION

Créer un fichier d'exclusion couvrant les fichiers d'environnement et les dossiers de travail. **Révoquer et régénérer les trois identifiants**, la clé personnelle PostHog devant de toute façon l'être après usage. Ne conserver localement que les variables publiques préfixées pour le client.

E2. La chaîne de publication Android expose la clé de signature à des dépendances mutables

Le processus de publication manipule le magasin de clés de signature, ses mots de passe et le compte de service Google Play. Il appelle deux actions tierces, toutes deux référencées par un **tag mutable** plutôt que par une empreinte de commit. Aucun des cinq dépôts ne déclare de restriction de permissions sur son jeton d'intégration continue.

Le scénario d'exploitation est direct : le mainteneur d'une de ces actions, ou quiconque prend le contrôle de son compte, republie le tag. À la prochaine publication, l'action reçoit les identifiants du compte Google Play, et la clé de signature est présente dans l'espace de travail. Une clé de signature Android compromise **ne se révoque pas**, elle condamne la fiche.

CORRECTION

Épingler chaque action sur une empreinte de commit complète, avec le tag en commentaire pour la lisibilité. Déclarer des permissions en lecture seule au niveau du processus, et n'ouvrir l'écriture que sur l'étape de publication. Activer le suivi automatisé des versions d'actions, absent des cinq dépôts.

E3. Aucun en-tête de sécurité sur l'application web publique

La configuration de déploiement ne déclare que la gestion du cache et l'autorisation du service worker. Il n'y a ni politique de sécurité du contenu, ni protection contre la détection automatique de type, ni politique de référent, ni politique de permissions, ni protection contre l'insertion dans un cadre. Le site vitrine n'a aucune configuration de déploiement.

L'impact immédiat est mesuré : le risque d'injection de code est nul par construction, la politique de sécurité du contenu joue donc surtout un rôle de garde-fou contre une régression future ou la compromission d'une dépendance. En revanche, l'absence de politique de permissions laisse la caméra, le micro et la géolocalisation accessibles à toute dépendance ajoutée plus tard, et l'absence de politique de référent transmet l'adresse complète des pages aux services de mesure.

POINT D'ATTENTION À LA MISE EN OEUVRE

Le site vitrine contient un script en ligne qui évite le clignotement au changement de thème. Une politique stricte le bloquerait. Il faut soit calculer son empreinte, soit le déplacer dans un fichier séparé, avant d'activer la règle.

Constats de gravité moyenne

M1. L'accès payant est falsifiable côté navigateur

L'état payant est conservé dans le stockage local du navigateur. Au démarrage, il n'est écrasé que si l'interrogation du service de facturation aboutit. En mode invité ou hors ligne, cette interrogation ne renvoie rien et une valeur modifiée à la main survit indéfiniment.

Ce qui maintient ce constat en gravité moyenne, c'est le chiffrage réel de la perte. Sur le web, l'état payant ne débloquent **qu'un seul mode de jeu**. Le contenu payant n'est pas embarqué dans le paquet livré : le catalogue ne contient que des métadonnées, titres et nombres d'éléments, aucune carte. Le préjudice maximal est donc un mode de jeu, pas le catalogue.

RECOMMANDATION, ET SON HONNÊTÉTÉ

Sans serveur, cet invariant **n'est pas tenable** côté client, et le rendre tenable coûterait une infrastructure serveur à une application dont la promesse est précisément de fonctionner hors ligne et sans compte. Il ne faut donc pas sur-concevoir. Trois mesures proportionnées suffisent : ne pas conserver l'état payant en clair mais le redériver à chaque démarrage connecté, borner la validité du cache à quelques jours d'inactivité, et surtout ne **jamais** faire descendre le contenu payant dans le paquet web, ce qui est déjà la règle appliquée.

Sur Android et iOS, l'état provient directement du composant de facturation et n'est pas réécrit sur disque par l'application. Le problème ne s'y pose pas.

M2. Le scan de secrets ne tourne que sur un dépôt sur cinq

Le dépôt web fait tourner un scan sur l'historique complet à chaque envoi et à chaque demande de fusion. C'est la bonne pratique, mais les quatre autres dépôts n'ont aucune étape équivalente, et le site vitrine n'a aucune intégration continue. Dupliquer cette étape sur les quatre autres, et activer côté forge la détection de secrets ainsi que le blocage à l'envoi sur les cinq.

M3 à M7. Hygiène et durcissements

- **Fichiers d'exclusion Git hétérogènes.** Seul le dépôt Android est complet. Les autres ne couvrent pas les magasins de clés, les certificats ni certains motifs de jetons. Aligner les cinq sur un bloc défensif commun.
- **Secret interpolé dans un script de publication.** L'exploitation est théorique puisque la valeur est contrôlée, mais le correctif tient en une ligne : passer par une variable d'environnement plutôt que par une insertion directe dans le corps du script.
- **Adresse du domicile publiée dans les mentions légales.** Ce n'est pas une non-conformité, c'est une **obligation** de l'article 6-III de la loi pour la confiance dans l'économie numérique pour un éditeur professionnel. C'est une exposition subie, à arbitrer avant la mise en avant publique du site, par une domiciliation commerciale le cas échéant, pas après.
- **Aucune surveillance des dépendances.** Aucun suivi automatisé sur les cinq dépôts, aucune vérification de vulnérabilités dans les chaînes d'intégration.
- **Bac à sable des scripts de compilation désactivé sur iOS.** Sur une machine qui manipulera bientôt des certificats de signature, c'est une réduction de défense à ne conserver que si un script l'exige réellement.

Ce qui est bien fait, et vérifié

Ces huit points ne sont pas des félicitations de politesse. Ce sont des acquis vérifiés par lecture de code ou par recherche exécutée, et ils expliquent pourquoi l'audit ne trouve aucun constat critique. Ils doivent être préservés lors des prochaines évolutions.

- **Aucun point d'injection de code.** La recherche des primitives d'insertion de contenu brut et d'évaluation dynamique ne remonte rien, sur aucun des cinq dépôts. Aucune vue web embarquée nulle part.
- **Le scénario du contenu malveillant ne s'applique pas.** Les paquets de contenu sont résolus à la compilation et rendus comme du texte, donc échappés. Injecter un contenu hostile suppose déjà d'écrire dans le dépôt.
- **Aucune donnée personnelle ne quitte l'appareil.** La recherche des primitives d'appel réseau sur le code source de l'application ne remonte que la constante d'hôte du service de mesure et un lien de crédit d'icônes. Aucun appel réseau écrit à la main, donc aucun prénom de joueur ne peut sortir.
- **Consentement conforme.** La mesure d'audience est désactivée par défaut, jamais pré-cochée, le refus est aussi accessible que l'acceptation, et l'expiration à six mois suit la recommandation de la CNIL. L'outil de mesure n'est chargé qu'après un choix explicite, sur une instance européenne.
- **Suivi des plantages sans donnée personnelle.** Les données personnelles par défaut sont désactivées, il n'y a ni traçage de performance ni rejeu de session, et un filtre supprime les informations de requête et d'utilisateur avant tout envoi. C'est au-dessus de la pratique courante.
- **Permissions mobiles minimales.** Deux permissions réseau, rien d'autre, avec la justification en commentaire. Sauvegarde automatique désactivée, une seule activité exposée.
- **Gestion des clés mobiles exemplaire.** Aucune clé en dur. Les deux plateformes lisent leur configuration depuis un fichier local ignoré ou depuis l'environnement, et dégradent proprement en

mode invité sans clé.

- **Les scripts d'outillage ne journalisent jamais la valeur d'une clé**, seulement le nom des variables chargées, et lisent le fichier d'environnement directement au lieu de passer le secret en argument de ligne de commande.

Recherche de secrets, résultats d'exécution

HISTORIQUE COMPLET DES CINQ DÉPÔTS

```
la-taverne           : 0 correspondance sur 120 commits
la-taverne-android   : 0 correspondance sur  72 commits
la-taverne-ios        : 0 correspondance sur  48 commits
la-taverne-content    : 0 correspondance sur  64 commits
la-tournee-site       : 0 correspondance sur   1 commit
-----
                      0 correspondance sur 305 commits
```

Motifs recherchés : clés secrètes et de test de paiement, jetons de forge et jetons d'accès personnels, clés de projet et jetons d'organisation de supervision, rôle de service de base de données, clés d'accès et clés d'interface de programmation des grands fournisseurs, et blocs de clé privée.

Sur l'état courant des dépôts, les seules correspondances relevées sont, d'une part, des **lignes de fichiers d'exclusion** qui contiennent les motifs eux-mêmes, ce qui est le comportement attendu, et d'autre part la clé publique d'ingestion de la mesure d'audience, qui est publique par conception. Le paquet distribué ne contient **aucune clé d'administration**.

RECOMMANDATION MALGRÉ UN SCAN PROPRE

Les trois identifiants du constat E1 ont circulé dans une session de travail, et les transcriptions de session persistent sur le disque. **La rotation reste recommandée** indépendamment du résultat du scan. Elle coûte cinq minutes, l'incertitude coûte davantage.

Vérifications restant à exécuter

Vérification	État	Commentaire
Scan de l'historique des cinq dépôts	Fait	305 commits, zéro correspondance
Audit des dépendances de production	À faire	Peu de dépendances de production et aucune surface serveur, donc l'essentiel des alertes portera sur les outils de développement et ne sera pas exploitable en production. Trier sur ce critère, pas sur le score brut.
Relevé réel des en-têtes du site en production	À faire	À comparer au constat E3. L'hébergeur ajoute de lui-même le transport strict sur les domaines personnalisés, ce qui reste à confirmer par la sortie réelle et non à supposer.

Vérification	État	Commentaire
Test de falsification du premium en navigateur	À faire	La lecture du code indique que la falsification aboutit. Reste à le démontrer.

Ordre de traitement conseillé

1. **Révoquer et régénérer les trois identifiants** du constat E1, et ajouter le fichier d'exclusion de déploiement. C'est la seule action dont le coût d'inaction est immédiat.
2. **Épingler les actions de publication** et restreindre les permissions, avant la première publication sur les magasins. Après, il sera trop tard pour la clé de signature.
3. **Ajouter les en-têtes de sécurité**, en traitant d'abord le script en ligne du site vitrine.
4. Généraliser le scan de secrets aux cinq dépôts, aligner les fichiers d'exclusion, activer le suivi des dépendances.
5. Traiter les durcissements de gravité faible au fil de l'eau, sans en faire un préalable à la publication.

Audit réalisé le 5 août 2026 sur les cinq dépôts du projet La Tournée. Document interne BLF Lab's. Ce rapport ne contient volontairement aucune valeur de clé, aucun jeton et aucun chemin de secret exploitable, afin de pouvoir circuler sans précaution particulière.